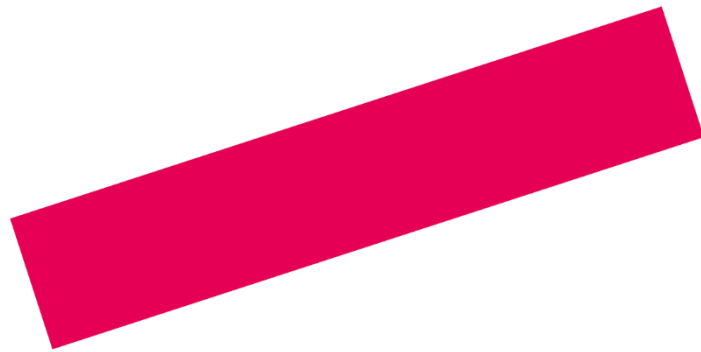




VEILIGE WEBAPPLICATIE MET PHP

WEBTEI03

Yassine kerkri
24 januari 2025

INHOUDSOPGAVE

INLEIDING	3
1 RISICO'S	3
1.1 Risicotabel.....	3
1.2 Gevolgen van een Doorbraak bij Dit Risico	4
1.3 Samenvatting van de Beveiliging van de Applicatie met Screenshot.....	5

INLEIDING

Dit verslag gaat over Web Technology: Implementatie en Beveiliging. Hier leg ik uit wat ik had gedaan. In deze opdracht heb ik gewerkt met de talen PHP, HTML en CSS. Ik heb geprobeerd om eenvoudige code te schrijven. Ik heb 6 pagina's gemaakt:

bestellingoverzicht_personeel.php, menu.php, Privacyverklaring.php, registratie_login.php, winkelmandje.php en profiel.php. Je kunt deze pagina's in de bijlage vinden. In dit verslag staat ook een risicotabel, zoals uitgelegd in hoofdstuk 7. Daarin geef ik een korte uitleg over de gevolgen van een doorbraak bij dit risico en hoe ik de applicatie heb beveiligd, met voorbeelden van screenshots en code uit mijn eigen applicatie.

1 RISICO'S

1.1 Risicotabel

Risicotabel 1: SQL-injectie	
Risico	R1: SQL-injectie vanuit views met logincomponent.
Aanvalstechniek	Broncodeinjectie: SQL.
Kans	Hoog: Staat in de top van de OWASP Top 10 (A03:2021 - Injection).
Gevolg	Hoog: Mensen met slechte bedoelingen kunnen toegang krijgen tot de database en belangrijke informatie lezen, veranderen of verwijderen.

Risicotabel 2: Broken Access Control	
Risico	R2: Onbevoegde toegang tot beschermde pagina's.
Aanvalstechniek	Ongecontroleerde toegang: Geen controle op sessies.
Kans	Hoog: Staat op nummer één van de OWASP Top 10 (A01:2021 - Broken Access Control).
Gevolg	Hoog: Gebruikers zonder toestemming kunnen gevoelige gegevens inzien of functies uitvoeren waarvoor zij geen rechten hebben.

Risicotabel 3: Cryptographic Failures	
Risico	R3: Onveilig opslaan van wachtwoorden.
Aanvalstechniek	Gebruik van zwakke of geen hashing.
Kans	Hoog: Veel toepassingen gebruiken verouderde of geen cryptografische beveiliging (A02:2021 - Cryptographic Failures).
Gevolg	Hoog: Gebruikers zonder toestemming kunnen gevoelige gegevens inzien of functies uitvoeren waarvoor zij geen rechten hebben.

Risicotabel 4: Identification and Authentication Failures	
Risico	R4: Onveilige sessies en authenticatie.
Aanvalstechniek	Sessies niet controleren of veilig opslaan.
Kans	Gemiddeld: Veel websites vertrouwen op sessies zonder extra beveiligingsmaatregelen (A07:2021 - Identification and Authentication Failures).
Gevolg	Gemiddeld tot hoog: Mensen met slechte bedoelingen kunnen sessies overnemen of toegang krijgen zonder wachtwoord.

Risicotabel 5: Security Misconfiguration	
Risico	R5: Onveilige serverconfiguratie.
Aanvalstechniek	Geen gebruik van beveiligingsheaders.
Kans	Gemiddeld: Veel applicaties missen eenvoudige configuratie zoals beveiligingsheaders (A05:2021 - Security Misconfiguration).
Gevolg	Gemiddeld tot hoog: Aanvallers kunnen scripts toevoegen of data stelen via zwakke configuraties.

1.2 Gevolgen van een Doorbraak bij Dit Risico

R1: SQL-injectie

Als iemand een SQL-injectie uitvoert, kan diegene toegang krijgen tot de database. Ze kunnen belangrijke gegevens bekijken, zoals wachtwoorden, of alles verwijderen.

R2: Broken Access Control

Als toegang niet goed gecontroleerd wordt, kunnen mensen dingen zien of doen die niet voor hen bedoeld zijn, zoals privégegevens bekijken of bestanden verwijderen.

R3: Cryptographic Failures

Als wachtwoorden niet goed beveiligd zijn, kunnen hackers deze stelen en gebruiken om in te loggen op accounts of andere systemen.

R4: Identification and Authentication Failures

Als sessies niet goed beveiligd zijn, kunnen aanvallers sessies overnemen. Hierdoor kunnen ze zonder in te loggen toegang krijgen tot accounts.

R5: Security Misconfiguration

Als servers niet goed zijn ingesteld, kunnen aanvallers schadelijke codes uitvoeren of informatie stelen. Bijvoorbeeld door het injecteren van scripts of het af luisteren van gegevens.

1.3 Samenvatting van de Beveiliging van de Applicatie met Screenshot

Toegang beperken (A01:2021 - Broken Access Control): Alleen ingelogde gebruikers met de juiste rechten kunnen bepaalde pagina's zien. Dit doe ik door sessies en rollen te controleren.

```
// Controleer of de gebruiker is ingelogd als klant
if (!isset($_SESSION['username']) || $_SESSION['role'] != 'Client') {
    header(header: "Location: registratie_login.php");
    exit();
}
```

Wachtwoorden beveiligen (A02:2021 - Cryptographic Failures): Wachtwoorden worden veilig opgeslagen met password_hash(). Bij inloggen worden ze gecontroleerd met password_verify().

```
if (isset($_POST['register'])) {
    $gebruikersnaam = $_POST['username'];
    $wachtwoord = password_hash(password: $_POST['password'], algo: PASSWORD_DEFAULT);
    $voornaam = $_POST['first_name'];
    $achternaam = $_POST['last_name'];
    $rol = $_POST['role'];
}
```

SQL-injecties voorkomen (A03:2021 - Injection): Ik gebruik voorbereide statements, zodat gebruikersinvoer veilig wordt verwerkt en geen gevaar vormt.

```

// Haal bestellingen op
$sql = "SELECT * FROM Pizza_Order WHERE client_username = ?";
$stmt = $db->prepare(query: $sql);
$stmt->execute(params: [$username]);
$bestellingen = $stmt->fetchAll(PDO::FETCH_ASSOC);
?>

```

Gebruikersidentiteit controleren (A07:2021 - Identification and Authentication Failures): Ik controleer of een gebruiker is ingelogd en een geldige rol heeft voordat hij een pagina opent.

```

if (!isset($_SESSION['username']) || $_SESSION['role'] != 'Personnel') {
    header(header: "location: registratie_login.php");
    exit();
}

```

Extra beveiliging toevoegen (A05:2021 - Security Misconfiguration): Ik heb beveiligingsheaders toegevoegd, zoals Content-Security-Policy, om te zorgen dat scripts en bronnen alleen van vertrouwde locaties komen.

```

header(header: 'X-Content-Type-Options: nosniff');
header(header: 'X-Frame-Options: SAMEORIGIN');
header(header: "Content-Security-Policy: default-src 'self';");

```

OPEN UP
NEW HAN_ UNIVERSITY
HORIZONS. OF APPLIED SCIENCES